

Vulnerability Assessment Planning Report

- **Target** : VulnApp Solutions Inc.
- **Application URL** : <http://143.198.205.185/>
- **Prepared By** : R.W.M.Chamod Krishantha Wanigasekara

Table of Contents

1. Executive Summary	page 2
2. Reconnaissance Strategy	page 3
3. Tool Selection & Justification	page 4
4. Detailed Methodology	page 5-6
5. Technical Findings	page 7
6. Risk Assessment Matrix	page 8
7. Recommendations	page 9
8. Active Assessment Scope	page 10
9. References & Appendices	page 11

1. Executive Summary

This passive reconnaissance assessment of VulnApp Solutions Inc.'s web application revealed multiple high-risk exposures without authentication. Key findings include:

-  **Admin panel (/admin.php) accessible publicly** exposing user data.
-  **Profile page (/profile.php) reveals PII via URL parameters** (IDOR risk).
-  **No SSL/TLS encryption** – all traffic is in plaintext.
-  **Verbose login error messages** disclose system details.
-  **HTML comments in /products.php** leak developer information.

Overall, the application demonstrates a **high-risk posture** with critical access control failures and sensitive data exposure.

2. Reconnaissance Strategy

- **Framework:** Phased approach (navigation → source inspection → headers → hidden endpoints).
- **Legal/Ethical:** Passive observation only; accessing /admin.php is valid since it is publicly served. Sensitive data must be redacted.
- **OpSec:** Clean browser profile, DevTools enabled, screenshots stored securely.
- **Objectives:** Enumerate endpoints, capture headers, identify exposed data types, map risks to OWASP Top 10.
- **Success Metrics:** All nav + hidden endpoints documented, all data categories classified.

3. Tool Selection & Justification

Category	Tools	Justification	Limitations
Browser Observation	Chrome DevTools, Firefox Inspector	Inspect headers, HTML source	Manual effort
Endpoint Enumeration	Burp Suite (passive mode), browser nav	Finds links, form actions	No brute force
Tech Fingerprinting	Wappalyzer, HTTP Headers	Detect PHP, server stack	Limited on bare IP
Documentation	Obsidian, Screenshots	Organized evidence	Needs discipline
Historical Analysis	Wayback Machine, Shodan	Archive lookup	Bare IP often missing

4. Detailed Methodology

Phase 1 – Scoping

Confirm target IP, prepare clean browser, record date/time.

Phase 2 – Endpoint Mapping

Visited /index.php, /login.php, /products.php, /search.php, /profile.php, /admin.php, /ping.php, /upload.php.

Documented titles, parameters, headers.

Phase 3 – Information Disclosure

- /index.php: App purpose, metadata.
- /products.php: Listings + hidden HTML comments.
- /admin.php: User table visible, sensitive categories.
- /profile.php: PII exposed via ?id= parameter.
- /login.php: Verbose error messages.

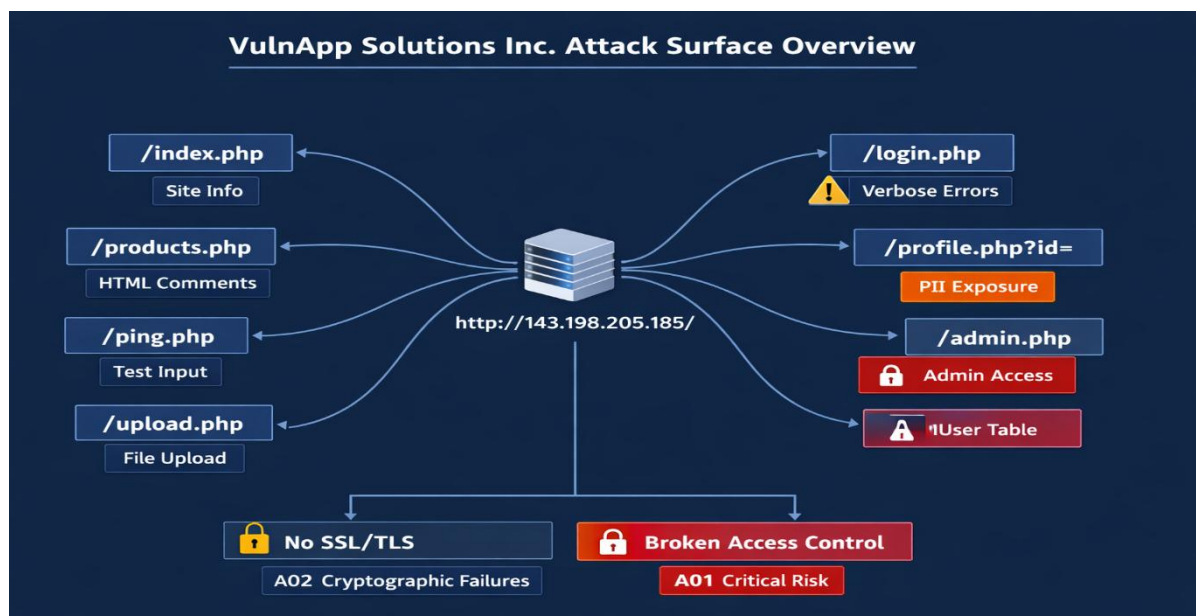
Phase 4 – URL Pattern Analysis

- Profile page IDOR risk (?id=).
- Admin panel in nav bar implies broken access control.

Phase 5 – Attack Surface Mapping

The following diagram illustrates the complete attack surface of VulnApp Solutions Inc.'s web application. Each endpoint is mapped to its associated data exposure and

OWASP risk category. The color-coded visualization highlights critical vulnerabilities such as the publicly accessible admin panel and insecure direct object references (IDOR) on the profile page. This mapping confirms that the application suffers from Broken Access Control (A01) and Cryptographic Failures (A02), both of which are high-priority remediation targets.



5. Technical Findings

Endpoint	Finding	Data Type	OWASP Category	Severity
/admin.php	Public admin panel	User table	A01 Broken Access Control	 Critical
/profile.php	IDOR risk	PII	A01 Broken Access Control	 High
/login.php	Verbose errors	System info	A03 Injection/Info Disclosure	 Medium
/products.php	HTML comments	Dev notes	A05 Security Misconfiguration	 Low
All pages	No SSL/TLS	All traffic	A02 Cryptographic Failures	 Medium

6. Risk Assessment Matrix

Finding	OWASP Category	Severity	Rationale
Admin panel exposed	A01	 Critical	No auth required
Profile PII via IDOR	A01	 High	PII accessible
No SSL/TLS	A02	 Medium	Data unencrypted
Verbose login errors	A03	 Medium	Reveals system info
HTML comments	A05	 Low	Leaks dev notes

7. Recommendations

- Restrict /admin.php behind authentication.
- Implement SSL/TLS immediately.
- Sanitize error messages to avoid information leakage.
- Remove sensitive HTML comments from source.
- Review access control design for all endpoints.

8. Active Assessment Scope

Based on passive findings, recommended active tests include:

- IDOR exploitation on /profile.php.
- Authentication bypass attempts on /admin.php.
- SQL injection testing justified by verbose login errors.
- Session management testing.
- File upload validation on /upload.php.

9. References

- OWASP Testing Guide v4.2
- OWASP Top 10 (2021)
- NIST SP 800-115
- MITRE ATT&CK Discovery Techniques